

基于生成论的网络安全分析能力调度系统

第 0 卷：导览与基础（第二版）

李龙胜

2026 年 6 月 16 日

这是整个理论体系的入口。

10 分钟理解核心思想，然后选择你自己的阅读路径。

防御方工程师、红队成员、AI 安全研究者、
博弈论学者、安全架构师、产品开发者——

各有不同的推荐路线。

摘要

第 0 卷是整个理论体系的引导文档。00 号文档提供了核心思想概览和阅读路径指南，帮助新读者在 10 分钟内理解“够用就行”原则如何解决安全运营中的告警洪流问题，以及这个原则如何从防御方扩展到攻击方博弈，再延伸到 AI 化攻防的三维均衡框架。01 号文档提供了所有关键符号的统一索引。02 号文档提取了生成论的四条公设和生成步系统的四个基本对象，作为所有后续卷组的公共数学基础。本卷第二版新增了体系全景图和六条细化阅读路径。

目录

1	00-导读：这个理论体系要解决什么问题	1
1.1	问题：告警洪流与有限分析能力的矛盾	1
1.2	核心思想：够用就行	1
1.3	这套理论的规模	2
1.4	这套理论的独特之处	2
1.5	体系全景图	2
1.6	阅读路径：你应该读哪些部分	4
2	01-核心概念速查	5
2.1	告警分级与分析能力	6
2.2	柯克霍夫原则与安全定义	6
2.3	攻击方与博弈	6
2.4	AI 化攻防（新增）	7
2.5	生成步系统（数学基础）	7

3 02-生成论公设摘要 8

3.1 四条公设 8

3.2 生成步系统的基本对象 8

3.3 贪心最优性定理（简略版） 9

3.4 最优记录粒度的核心公式 9

3.5 诚实标注 9

1 00-导读：这个理论体系要解决什么问题

1.1 问题：告警洪流与有限分析能力的矛盾

一个中型企业的安全运营中心每天可能产生超过 3 万条告警。负责分析这些告警的一线分析师通常只有 3 到 5 人。每条告警都看，人力无法承受；随机抽检，可能漏掉真正的攻击信号。

这不是个别企业的问题，而是整个安全行业的共同困境。无论投入多少资金购买安全设备，最终分析告警的还是人——而人的精力是有限的。

1.2 核心思想：够用就行

这个理论体系的核心思想极其简单，只有一句话：

不是追求最高精度，而是追求刚好够用的安全。

我们承认安全团队的精力是有限的。在这个前提下，数学告诉我们：对每一类告警，存在一个“最优分析率”——不是 100% 分析，也不是完全忽略，而是在漏报损失和分析成本之间找到最低总成本的平衡点。

这个最优分析率由一套严格的数学公式算出，并且可以随着威胁态势的变化自动调整。

1.3 这套理论的规模

从这一个核心思想出发，我们已经完成了以下模块：

模块分类	内容	文档数量
核心理论体系	四卷（防御方、对抗性安全、攻击方、高阶专题）	4 卷
扩展模块	蜜罐、分布式欺骗、UEBA、SOAR、告警分流等	9 篇
AI 化攻防专题	推理成本、弹药质量、速率边界、三维均衡	7 篇
博弈论统一框架	探测、逼移、多攻击方协同、战场转移	1 篇
方法论与工具	强制去术语化、诚实标注、优雅降级、自噬效应	4 篇
产品与算法	产品蓝图、生产级引擎、模型生命周期管理	3 篇

1.4 这套理论的独特之处

- **算法完全公开：**所有的公式、流程、反馈规则都写在白皮书里，任何人都可以审查。
- **安全性不依赖算法保密：**借鉴密码学的柯克霍夫原则（算法公开，密钥保密），系统的安全性收敛到一组秘密参数上。攻击者即使完全了解算法，也无法精确预测裁定阈值。

- **攻防双方统一建模：**攻击方同样是一个生成步系统——每一次攻击尝试消耗资源，受容量约束，遵循够用就行原则。攻防双方在同一个数学框架下博弈。
- **AI 时代的冷水：**当攻防双方都部署大模型时，AI 不会给任何一方带来碾压式优势。攻击方按需生成的低成本优势、对抗样本军备竞赛的对称性、防御方 AI 成本陷阱的三重困境——共同指向够用就行原则在 AI 时代同样有效。
- **诚实的边界标注：**每一处推导都标注了它的可信程度（I 级/II 级/III 级）。我们不会假装知道我们不知道的东西。

1.5 体系全景图

以下表格列出了所有已完成模块及其前置依赖关系，读者可以按图索骥。

模块	内容摘要	前置依赖
核心理论体系（四卷）		
第 0 卷	导览、符号表、公设摘要	无
第 1 卷	告警分级算法、实施指南、GS 实例化	第 0 卷
第 2 卷	柯克霍夫原则、-参数不可区分性、探测与反探测	第 0 卷、第 1 卷
第 3 卷	攻击方 GS、逼移策略、红队决策树、多攻击方协同	第 0-2 卷
第 4 卷	分析能力深层结构、同源关联优先、产品蓝图、诚实标注总表	第 0-3 卷
扩展模块（独立补充命题）		
安全参数自适应调节	四层分配扩展到自适应安全级别	第 1-2 卷
SMPC 协同逼移与对抗	攻击方利用安全多方计算的协同攻击	第 3 卷
零知识证明生成成本	最优审计聚合周期	第 2 卷、产品蓝图
动态与静态张力	柯克霍夫原则与密码学的根本矛盾	第 2 卷
攻击方联盟信任锚定	战略级与黑产级攻击方的信任锚定模型	第 3 卷
信任锚定独立文档	跨领域结构分析工具	问题六
自适应蜜罐运维	引流时机与蜜罐真实性经济模型	第 1-3 卷
分布式欺骗防御	欺骗密度、多样性与路径一致性	蜜罐模块
扩展分析路径统一调度	NDR、沙箱、TIP、漏洞管理、CWPP 调度	第 1 卷、产品蓝图
高优先级扩展模块		

UEBA 桥接 SOAR 剧本优化 告警分流矩阵 生产级算法	基线粒度的最优裁定 时间衰减、依赖关系与优雅降级 从 4 条到 9 条分析路径的统一路由 8 模块完整代码	第 1 卷、第 2 卷 第 1 卷、产品蓝图 第 1 卷、扩展分析路径 第 1-4 卷
AI 化攻防专题系列		
AI 化攻防专题卷	推理成本、对抗样本、贪心择优 AI 维度	第 1-4 卷
AI 化攻防批判 弹药质量维度深化 柯克霍夫边界条件 贪心严格证明	对称性博弈、战场转移、AI 成本陷阱 分层分配、Stackelberg 非对称性 扰动频率、探测速率、三维均衡 单维贪心最优性在 AI 博弈维度的证明	AI 专题卷 AI 专题卷、AI 批判 第 2 卷、弹药质量深化 第 1 卷、AI 专题卷
联合收敛性深化 模型生命周期管理	联合凸性、退化效应、离散粒度 模型维护、退役与供应链安全	贪心严格证明 AI 专题卷、生成论 AI 总纲
博弈论统一框架		
攻防博弈论统一框架	信号博弈、逼移动态博弈、合作博弈、AI 战场转移	第 2-3 卷、AI 系列
方法论与工具		
强制去术语化 诚实标注三级体系 优雅降级原则 自噬效应识别	思考方法论 I/II/III 级标注标准 资源紧缺时的普遍应对策略 防护层消耗自身能力的普遍规律	无 无 SOAR 优化 UEBA、审计、蜜罐

1.6 阅读路径：你应该读哪些部分

快速了解核心思想（15 分钟）：

- 读本导读（你正在读的这个）。
- 读第 1 卷 1.1（问题与模型）——了解最优分析率是怎么算出来的。
- 读第 1 卷 1.2（实施指南）——了解如何用 Excel 和 Python 落地。

防御方工程师（希望在自己的 SOC 中部署这套系统）：

- 读第 0 卷全部（本卷）。
- 读第 1 卷全部（告警分级算法和实施细则）。
- 读第 2 卷 2.1（柯克霍夫框架初建）——了解参数保密机制。

- 读告警分流矩阵和扩展分析路径统一调度——了解如何联动多设备。
- 可选：读生产级算法——直接部署。

红队成员（希望理解如何对抗这套系统）：

- 读第 0 卷全部。
- 读第 2 卷（了解防御方如何隐藏参数）。
- 读第 3 卷全部（攻击方策略、逼移、决策树、多攻击方协同）。
- 读自适应蜜罐运维和分布式欺骗防御——了解如何反制防御方的欺骗。
- 读攻击方联盟信任锚定——了解如何协同或瓦解联盟。

AI 安全研究者（希望理解 AI 化攻防的博弈结构）：

- 读第 0 卷全部。
- 读第 2 卷（柯克霍夫原则是 AI 时代参数保护的基础）。
- 读 AI 化攻防专题卷和批判文档——理解推理成本和战场转移。
- 读弹药质量维度深化——理解质量维度的 Stackelberg 非对称性。
- 读柯克霍夫边界条件——理解速率博弈和三维均衡框架。
- 读贪心严格证明和联合收敛性深化——理解博弈论基础。

博弈论研究者（希望理解攻防博弈的统一结构）：

- 读第 0 卷全部。
- 读第 2 卷和第 3 卷——获取博弈的基本设定。
- 读攻防博弈论统一框架——探测信号博弈、逼移动态博弈、合作博弈、AI 战场转移。
- 读信任锚定独立文档——理解多方系统的信任结构。

安全架构师（希望了解整体设计和产品化路径）：

- 读第 0 卷全部。
- 读第 1 卷 1.1（核心算法）。
- 读第 2 卷 2.1（柯克霍夫框架）。
- 读第 4 卷 4.2（产品落地蓝图）和 4.3（诚实标注总表）。
- 读告警分流矩阵和扩展分析路径统一调度。
- 读生产级算法和模型生命周期管理。

学术研究者（希望深入理解数学基础）：

- 读第 0 卷全部。
- 读全四卷。
- 读附录 B（数学推导补遗）。
- 读维护工具包中的开放问题清单。
- 读 AI 化攻防全部七篇——这是最具研究价值的扩展方向。

2 01-核心概念速查

以下表格列出了整个理论体系中反复出现的关键符号及其一句话定义。每个符号的正式锚点在维护工具包中可查。

2.1 告警分级与分析能力

符号	含义
r_i	告警类别 i 的分析率（被分析的概率）， $r_i \in [0, 1]$
r^*	最优分析率，由贪心择优裁定
A_i	告警类别 i 攻击成功时的最大损失（货币化度量）
α_i	告警类别 i 对漏报的敏感度系数
β_i	告警类别 i 的结构特征常数， $\beta_i = \alpha_i A_i^2 / (2B_i)^2$
B_i	告警类别 i 的攻击手法变化率（带宽）
κ	单条告警的单位分析成本
C	每日总分析能力预算（容量上限）
C_{consumed}	已消耗的分析能力（实部）
C_{reserve}	保留的分析能力（虚部）
$\mathcal{K}_{\text{covered}}$	当前分析能力有效覆盖的告警类型集合
V_{breadth}	虚部广度， $ \mathcal{K}_{\text{covered}} /K$
V_{risk}	虚部风险暴露，未被覆盖类型的潜在损失之和
$q_{\min}$	同源关联优先策略的生效阈值

2.2 柯克霍夫原则与安全定义

符号	含义
θ	防御方的秘密参数集合（ $A_i^{\min}, \alpha_i$ 等）
ε	参数不可区分性的安全参数（越小越安全）

δ	参数周期性扰动的幅度
T_{rot}	参数扰动周期
q_{01}	蓝队伪造概率：将忽略伪装为分析
q_{10}	蓝队压制概率：将分析伪装为忽略
Δ	两个参数集合 θ_0 和 θ_1 对应的可观测差异
M_{max}	攻击方对单个告警类型的探测预算上限
m^*	区分参数所需的最小探测次数（信息论下界）

2.3 攻击方与博弈

符号	含义
ℓ	攻击方的质量等级, $\ell \in [0, 1]$
C_A	攻击方总资源预算（算力 + IP 池）
q_{hit}	单次攻击尝试命中防御方脆弱点的概率
ρ	攻击方对信息暴露的敏感度系数
$s(t)$	防御方分析能力饱和度
$\tau(t)$	防御方响应延迟（饱和指标之一）
θ_{mn}	攻击方 m 和 n 之间的协同参数

2.4 AI 化攻防（新增）

符号	含义
q_A	攻击方对抗样本生成质量（逃逸概率）
q_D	防御方 AI 模型检测质量（检测率）
λ	攻击方质量对防御方有效检测率的衰减系数
$C_A(q_A)$	攻击方质量生成成本函数，严格凸
$C_D(q_D)$	防御方质量训练成本函数，严格凸
f_D	防御方扰动频率
R_A	攻击方探测生成速率
T_A	攻击方完成一轮完整探测校准所需时间
$h(t)$	AI 模型在时刻 t 的健康评分

2.5 生成步系统（数学基础）

符号	含义
$R_{\min}$	最小记录量（公设二的数学表达）
s_T	系统在逻辑时间 T 的状态
U	生成步（作用在状态上的操作）
$R(s, U)$	记录成本函数
$\mathcal{A}(s)$	状态 s 处允许的生成步集合
$J(\pi)$	路径 π 的累积记录成本
$f(s)$	单调进展函数（贪心最优性定理的条件）

3 02-生成论公设摘要

本摘要从 Math-51 和生成步系统文档中提取，作为全四卷及所有扩展模块的公共数学基础。更详细的数学定义和证明见附录 B。

3.1 四条公设

公理 3.1 (过程性). 系统在任何状态下都不能卡死。对任何状态 s ，允许的生成步集合 $\mathcal{A}(s)$ 非空。

安全运营含义：任何时候，分析师或 AI 至少有一个可选操作（即使只是“忽略这条告警”），系统不会陷入僵死。

公理 3.2 (记录性). 每一步必然产生不可逆的记录成本。存在最小记录量 $R_{\min} > 0$ ，使得对所有 s 和 $U \in \mathcal{A}(s)$ ，有 $R(s, U) \geq R_{\min}$ 。

安全运营含义：分析告警、封禁 IP、甚至只是“看一条告警”都必然消耗不可回收的精力/算力。不存在零成本的安全操作。

公理 3.3 (够用就行原则). 在每一步，系统选择使当前记录成本最小的生成步。不需要全局最优规划，只需要每一步的局部贪心选择。

安全运营含义：对每类告警，系统自动选择最优分析率——不是追求完美，而是在有限精力下做到刚好够用。

公理 3.4 (观测自洽). 记录成本函数 R 不依赖于观测者的内部约定选择。不同观测者得到的成本度量一致。

安全运营含义：同一个台账参数，不同分析师使用时得出的最优分析率是一致的。系统产出可复现、可审计。

3.2 生成步系统的基本对象

定义 3.1 (生成步系统). 一个生成步系统 $\mathcal{G}$ 由以下四个组件构成:

- (1) 状态空间 $\mathcal{S}$: 系统的所有可能状态。
- (2) 生成步集合 $\mathcal{A}(s)$: 在状态 s 处允许的操作集合。
- (3) 记录成本函数 $R(s, U)$: 在状态 s 下执行生成步 U 所产生的成本。
- (4) 容量上限 C : 累积记录成本不得超过此值。

安全运营实例化 (防御方):

- 状态空间 = 当前安全态势 + 已消耗的分析能力。
- 生成步 = 告警分析操作 (忽略/自动分析/人工深度分析)。
- 记录成本 = 漏报损失 + 分析耗时。
- 容量上限 = 每日总工时预算。

攻击方实例化:

- 状态空间 = 剩余算力 + IP 池 + 对防御方参数的信念。
- 生成步 = 攻击尝试 (选择目标、告警类型、质量等级)。
- 记录成本 = 算力消耗 + IP 消耗 + 信息暴露风险。
- 容量上限 = 攻击资源总预算。

3.3 贪心最优性定理 (简略版)

定义 3.2 (贪心择优). 在每一步 T , 已知当前状态 s_T , 系统遍历 $\mathcal{A}(s_T)$ 中所有生成步, 选择使局部记录成本 $R(s_T, U)$ 最小的那个:

$$U_T = \arg \min_{U \in \mathcal{A}(s_T)} R(s_T, U).$$

核心定理 (贪心最优性定理): 在进展单调性和成本凸性的条件下, 每步贪心择优等价于全局最优路径。每一步局部最优选择, 在长期上达到全局最优结果。

安全运营含义: 分析团队不需要做长期规划, 只需要每一步都选择当前成本最低的分析操作。这套“懒人策略”在数学上被证明是最优的。

3.4 最优记录粒度的核心公式

(详细推导见 Math-51 和附录 B)

最优分析率 r^* 由以下方程决定:

$$\frac{1-r}{r^4} = \frac{\kappa}{2\beta},$$

其中 $\beta = \alpha A^2 / (2B)^2$ 是信号特征常数, κ 是单位记录成本。

在安全运营的简化版本中 (线性模型), $r^* = 1$ 若 $\alpha A > \kappa$, 否则 $r^* = 0$ 。当总工时约束紧张时, 按 β_i 降序分配分析能力。

3.5 诚实标注

- 本摘要是对生成论公设体系的极简呈现，完整内容见生成步系统（第一、二卷）和 Math-51。
- 贪心最优性定理的严格数学证明见附录 B——此处仅给出直观描述。
- 最优记录粒度的非线性公式在实际部署中可先用线性模型，待数据积累后迁移。

文档信息：

- 作者：李龙胜
- 版本：v2.0（第二版——新增体系全景图和六条细化阅读路径）
- 许可：CC BY 4.0
- 关联文档：全四卷、全部扩展模块、AI 化攻防专题系列、博弈论统一框架、附录、维护工具包